

# CSCM Tool

Controller Status Code Management Tool

## Software description

What the software is and does

| | |
|---|---|
| Version | 4.18.1 |
| Date | 2026-10-29 |
| Commit | a741076 |
| Source digest | 76aa9e7e95cba7bb617fb31d (SHA-256 of the source files) |

Generated from the Markdown documents of the repository by scripts/build_docs_pdf.py; do not edit by hand. Status symbols are written as words (OK, FAIL, yes), arrows and comparison signs as ASCII (->, <=, >=). The same version number is shown in the menu of the application and in /api/v1/health.

# 22. Software Description — CSCM Tool

**Document type:** software description (what the delivered software is and how it behaves). It is a separate artefact from the requirements specification (`03-srs.md`), the user manual (23-user-manual.md) and the test report ( 24-test-report.md). **Describes:** the implementation in `cscm_tool/` as of 2026-10-24 (v4.10), branch `dev`, against requirements baseline v4.0 (the v3 field model plus the improvement pack of 21-improvement-ideas.md; sections and rows added by v4 are marked (v4)). **Traceability:** every statement about behaviour cites the requirement it implements (FR-/BR-/SEC-/NFR- IDs from `03-srs.md` and `11-security-architecture.md`); 20-traceability-matrix.md maps each of those to code and automated tests.

---

## 1. Purpose and scope

### 1.1 Purpose

The **Controller Status Code Management Tool (CSCM Tool)** is the governed system of record for the status codes of Senvion 4XM/3XM/2XM wind-turbine **Main Controllers** and **Hub Controllers**: the faults, warnings and informational messages the controller software raises. It reverses the former document-first practice — codes are created, completed, reviewed, approved, versioned and released inside this tool, and technical manuals, specifications and SCADA tag lists are derived from it.

### 1.2 What the software does

1. Holds each status code with a stable identifier `StCd-XXXXX`, a rich field set (category, delays, counters, program references, the further programs, parameters and user-group levels of the generated programs, eight audience-access values) and complete revision history.
2. Enforces a **seven-state lifecycle** — Draft -> Review -> PendingApproval -> Approved -> Released -> Deprecated -> Archived — with **three independent decisions** before release: a Reviewer sign-off, an Administrator sign-off, and a Chief Engineer approval (FR-030–FR-039, BR-004, BR-005).
3. Routes work to the right engineers with **Cross-Domain Sign-Off** (FR-027–FR-029).
4. Allocates identifiers atomically per Functional System Group and Subgroup (FR-021).
5. Bundles approved codes into immutable **Releases** and exports them as CSV, JSON, XLSX or PDF (FR-040–FR-048).
6. Imports a legacy library from CSV/XLSX — always as governed Drafts, never as a shortcut (FR-048a–d).
7. Records every governed action in an append-only **audit log** (FR-070–FR-073).
8. Provides **sandbox** codes for training and testing that can never reach a Release (FR-053–FR-056).
9. Offers a server-rendered web UI (50 screens, nineteen languages) and a versioned JSON REST API (`/api/v1`, 171 operations).
10. (v4) Protects engineering work and approvals: lost-update detection on Drafts (FR-090), reference and duplicate warnings with a Where-used list (FR-091 … FR-093), password confirmation for sensitive actions (FR-126), delegation for absences (FR-125), SLA ageing with reminders (FR-120, FR-121), change sets, field comments, review checklists and evidence (FR-124, FR-127 … FR-130).
11. (v4) Publishes trustworthily: export profiles, audience-, language- and software-version-scoped exports, manifests with SHA-256 hashes (optionally signed) and ZIP bundles, release notes, an offline lookup page, translations, planned dates (FR-100 … FR-111).
12. (v4) Helps with the migration and with insight: import template, dry run, update mode and reconciliation (FR-048i … FR-048n); catalogue health and capacity forecast, KPIs, saved searches, fleet feedback, Hub-to-Main consolidation (FR-123, FR-140 … FR-147).
13. (v4) Operates safely on-premises: verified backups, a hash-chained audit log, readiness and metrics endpoints, scoped API tokens, a change feed and signed webhooks, installers, systemd units and CI definitions (FR-144 … FR-153, NFR-009 … NFR-014).

### 1.3 What it deliberately does not do

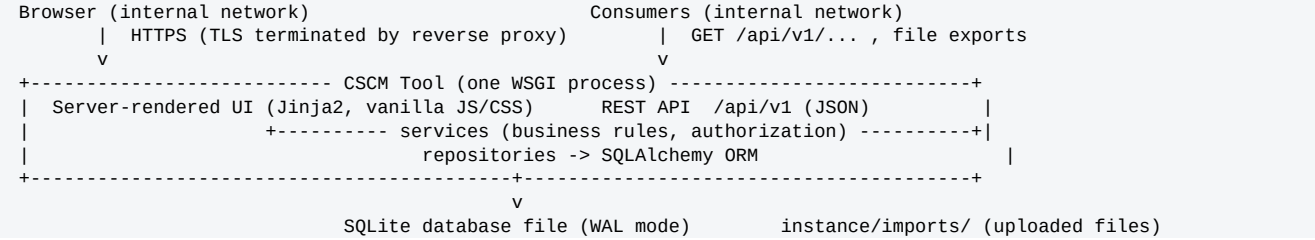
| Not in scope | Reason / reference |
|---|---|
| Single sign-on with Active Directory/ADFS | Phase 2; the AuthProvider seam is built (FR-005, SEC-005) |
| Any cloud service — hosting, identity, storage, telemetry, CDN | Hard constraint C-004a, NFR-008 |
| Configurable approval chains | The three-decision model is fixed (16-mvp-roadmap.md §2) |

| Not in scope | Reason / reference |
|---|---|
| Push integration into SCADA or documentation tools | Consumers pull via API, change feed or signed webhooks on the internal network (A-004, FR-144 ... FR-146) |
| Mobile-optimised layout; languages beyond the nineteen of FR-157 | Excluded; see 21-improvement-ideas.md |
| Running on PostgreSQL | Only prepared (inventory and ratchet, NFR-014); not done |
| Bulk import that bypasses review | Reversed C-005: import is allowed but fully governed (FR-048c) |

### 1.4 Intended users

Six roles (SEC-012 default is Viewer): **Administrator** (Product Owner / Component Owner Controls Software, the highest level, shown red), **StCd Owner** (owner of the library: read-only oversight and role changes among Viewer, Engineer and Reviewer), **Engineer**, **Reviewer** (Sub-PO for Status Codes), **Chief Engineer**, **Viewer**. Engineers may additionally hold one or more **Engineering Domain tags** (Controls, Electrical, Mechanical, Grid, Safety) that determine which cross-domain sign-offs they can give. Detailed role guidance is in the user manual.

## 2. System context




- Everything runs on the organisation's own servers; there is **no outbound dependency** (NFR-008). A test runs the whole lifecycle with all sockets blocked.
- The UI shares the **OneTool visual shell** (top bar, sidebar, tokens) but keeps its **own login and credential store** (SEC-006).

## 3. Technology

| Layer | Choice | Notes |
|---|---|---|
| Language / framework | Python 3.12, Flask 3.1 | Constraint C-003 |
| Persistence | SQLite (WAL), SQLAlchemy 2.0, Alembic migrations | C-001; repository pattern keeps PostgreSQL possible (NFR-004) |
| UI | Jinja2 templates, hand-written CSS and vanilla JavaScript | No framework, no CDN; enforced by a Content-Security-Policy |
| Passwords | Argon2id (argon2-cffi) | SEC-001 |
| CSRF | Flask-WTF synchroniser tokens | NFR-003 |
| Exports | built-in csv/json/zipfile/hashlib/hmac, openpyxl (XLSX), fpdf2 (PDF) | Pure Python, no system packages |
| Search | SQLite FTS5 (optional, with substring fallback) | FR-148 |
| Serving | Waitress (Windows) or any WSGI server behind a TLS-terminating proxy | 14-deployment-architecture.md |
| Quality | pytest, coverage, schemathesis/hypothesis, black, ruff, mypy, bandit, pip-audit | 15-development-standards.md, 13-test-strategy.md §11 |
| Packaging (v4) | deploy/ installers (PowerShell, bash), systemd units, scripts/serve.py, scripts/ci.py, CI definitions for Gitea / GitLab | 14-deployment-architecture.md §4a |

## 4. Architecture

## 4.1 Layering

```
app/
  api/v1/      JSON endpoints (routes only: parse request, call a service, serialise); one module per area
  ui/          Server-rendered views (same services as the API); one module per area
  services/    All business rules and authorization ? the only place rules live (v4: publication,
               governance, import, integration and operations services, see 08-system-architecture.md §2)
  repositories/ Query encapsulation over the ORM (status codes, releases, change requests, FTS)
  models/      SQLAlchemy tables (mirror docs/artifacts/schema.sql; operations.py = v4 tables)
  domain/      Cross-cutting domain code: errors, lifecycle state machine, role checks
  export/      CSV / JSON / XLSX / PDF / offline bundle / full-database writers
  auth/        Password hashing, session loading, rate limiting (database-backed), delegation-aware decorators
  audit_chain.py audit_hash.py   hash chain, verification, archive (v4)
  observability.py logging_config.py   metrics and JSON request log (v4)
  i18n.py i18n_de.py i18n_extra.py help_content.py   catalogues (German complete; French, Hindi, Georgian, Arabic an
  d ten more for the main strings) and help text
  cli.py       flask jobs (create-admin, backup-db, verify-backup, send-reminders, audit-verify, audit-archive, veri
  fy-export)
  templates/, static/   UI
migrations/    Alembic (baseline applies schema.sql; follow-on migrations are guarded and idempotent)
tests/         unit, integration, system, performance, fixtures
scripts/       generate_test_report.py, ci.py, serve.py, pg_readiness.py, gen_api_summary.py, gen_translations_doc.p
  y
deploy/        linux/ (installer, systemd units, nginx sample), windows/ (installer, task scripts)
```

Rules that follow from the layering (SEC-010, `15-development-standards.md`): routes never contain business logic; role checks exist **both** in route decorators and in the service layer (`require_roles`), so a future caller cannot reach a privileged operation by omission; the UI and API call the same service methods, so behaviour cannot diverge.

## 4.2 Request handling

1. `before_request` assigns a request id (written to every audit entry).
2. The auth decorator loads the user from the signed session cookie and re-validates, on **every request**: idle timeout (30 min), absolute lifetime (12 h), account still active, password unchanged since login (so deactivation and forced resets take effect immediately).
3. CSRF is checked for state-changing requests (UI via form token, API via `X-CSRFToken`).
4. The service performs the action in **one database transaction** and writes the audit entry in the same transaction.
5. `after_request` adds the security headers (§9.3).

## 4.3 Logging

Structured JSON, one object per line on standard error and, with `LOG_FILE`, in a rotating file ( `app/logging_config.py`, `11-security-architecture.md` §11): timestamp, level, request id, method, path, status, duration, authenticated user id, client address; unhandled exceptions with the stack trace and request id. Credentials, session tokens, request bodies and query strings are never logged. Logs are diagnostics; the audit log is the business record.

## 4.4 Transaction model

(v4) Several worker processes may serve one database file: the rate limit, the audit chain and number allocation are all coordinated through the database write lock, and background imports report through their job row (NFR-009, 08-system-architecture.md §8). SQLite is single-writer. Writers start with `BEGIN IMMEDIATE` (race-safe identifier allocation, FR-021). Read-only requests (`GET/HEAD/OPTIONS`, except endpoints marked `@writes_on_get` such as the exports, which record an export job) use a deferred `BEGIN`, so in WAL mode readers do not block and are not blocked by a writer (NFR-004). `busy_timeout` is 15 s so writers queue rather than fail.

---

# 5. Domain model

## 5.1 Core entities (tables in docs/artifacts/schema.sql)

| Entity | Purpose |
|---|---|
| status_code | The identity of a code: identifier (StCd-XXXXX, or StCd-T##### for sandbox), Functional System Group + mandatory Subgroup, owner, legacy reference, sandbox flag. Never deleted unless sandbox (trigger-enforced). |

| Entity | Purpose |
|---|---|
| status_code_revision | A versioned set of descriptive/technical fields plus the three decisions' columns, lifecycle state, and the single is_current flag. Locked by trigger once Approved/Released/Archived. |
| status_code_revision_platform | Revision <-> Turbine Platform (2XM/3XM/4XM), multi-select. |
| change_request | The workflow carrier for one revision: type (NEW / REVISION / DEPRECATION / IMPORT), requester, state, optional assigned Reviewer. |
| review_comment | Role-tagged decisions and plain comments. |
| domain_signoff, domain_signoff_request | Cross-domain sign-offs and the requests for them. |
| release, release_item | A named, versioned bundle; immutable once published. |
| import_job | One library upload with counts and error report; (v4.2) ST for an import from generated programs, with the batch change_set_id. |
| (v4.2) import_source_item | One imported program: file, SHA-256, program number and every parsed attribute as JSON. |
| audit_log_entry | Append-only action log. |
| export_job | Record of each export. |
| user, user_engineering_domain, role | Accounts, domain tags, the six roles. |
| user_password_history | Hashes of retired passwords for the last-5 reuse block. |
| (v4) tables | 21 more: software versions and Release targets, languages and translations, export profiles, change sets, delegation, notifications, settings, rate-limit counters, evidence, field comments, review checklist and confirmations, saved searches, occurrence feedback, API tokens, webhooks and deliveries, Hub-to-Main mapping — field detail in 06-data-dictionary.md §13; the technical nomenclature (terminology_term, terminology_translation, v4.9); 65 tables in total (v4.2 adds import_source_item, status_code.reserved_identifier and the ST import source). |
| lookup_* (13 tables) | Controlled vocabularies: 12 Functional System Groups, 38 Subgroups, Turbine Platforms, Engineering Domains, Available Groups (23 codes), and eight audience-access vocabularies. Each has an optional description used as inline help; the eight audience-access vocabularies also carry audience_visible, and each group carries controller_type (MAIN/HUB) (v4). |

## 5.2 Identifier scheme

`StCd-XXXXX` — five digits. The number falls in the range of the code's **Functional System Group** and, within it, the **Subgroup's sub-band** (for example Converter & Grid Interface WCNV 1000–1999, subgroup Converter 1000–1199: the first subgroup of every Main Controller group owns the group's first 200 numbers, later subgroups 100 each). Twelve groups exist: nine Main Controller groups (1000–9999) and three Hub Controller groups (11000–13999; `WTUR` and `WROT` are intentionally reused with different ranges, so a group is always resolved by id or range, never by prefix alone). The ranges 10000–10999, 14000–14999, 15000–15999 and 16000–16999 are reserved free capacity that an Administrator can assign to a new group without a deployment (FR-048g/h).

Rules: an identifier is **assigned once, at Submit for Review**, never while Draft (FR-021); a Draft shows "Not yet assigned". It never changes (BR-001) — a rejected-and-resubmitted CR and every later revision keep it. Numbers are not reused. An Administrator may submit with a manual identifier for a documented migration or reservation case, which is validated (format, sub-band, unused), requires a reason, and is audited (FR-021a). Sandbox codes draw from a separate `StCd-T#####` counter that never overlaps a real range (FR-053).

## 5.3 Field set of a revision

Grouped as in the data dictionary (`06-data-dictionary.md`): Classification (group, subgroup, turbine platforms, legacy reference); Description (title <= 120 characters, description 10–4000, software version); Behaviour (status category ERROR/WARNING/INFO, available group, alarm flag, set delay and reset delay such as `10ms` or `2min`, up/down counter, trigger snapshot, loadless spinning permitted); Repeated-error escalation (times repeated, window, escalation code); Program references (eight numeric references: yaw, manual reset, auto reset, converter reactive power, brake, converter programs GSC/MSC, yaw-bearing lubrication); Audience access (Development, Sales, TCC, Service, Turbine Operator Package, Grid Operator, Service Partner, Customer — eight independent values).

## 5.4 Ownership of fields and cross-domain sign-off

Title, description, category and available group belong to no domain. The timing, repeated-error and program-reference fields belong to **Controls**. If the originating Engineer does not hold the Controls tag, a Controls Engineer must record a sign-off before the CR can be submitted (FR-027, FR-029, BR-011). The originating Engineer

can send an explicit **sign-off request**, optionally addressed to a named Engineer; it appears on that person's Dashboard and My Change Requests until signed (FR-028). The audience-access fields are governed separately (below).

(v4) A revision also carries the optional remedy text, affected component, related codes and standard references, an inclusive software-version range, planned effective/deprecation dates, and `row_version` / `updated_at` for lost-update detection (06-data-dictionary.md §2).

### 5.5 Restricted audience-access fields

The Engineer may propose the eight audience-access values while drafting. They are **not authoritative** until the Administrator's Review sign-off confirms them; at that moment the Administrator can change any of them in the same action, and the change is audited (FR-025a, FR-034, BR-012, SEC-013). Until then the UI marks them "Proposed".

---

## 6. Lifecycle and workflow

### 6.1 State machine

```
        submit                  both sign-offs               Chief Engineer              publish
 DRAFT --------> REVIEW -------------------> PENDING_APPROVAL -----------> APPROVED ---------> RELEASED
   ^                |  reject (comment)              |  reject (comment)       |
   +----------------+--------------------------------+          (deprecation CR approved)
                                                    PENDING_APPROVAL -----> DEPRECATED ---> ARCHIVED
                                                                              | reinstate (Administrator, reaso
  n)
                                                                              +------------> RELEASED
```

The nine permitted transitions are defined once in `app/domain/lifecycle.py` and enforced for every assignment to a revision's state; any other transition raises an error (BR-004). Tests check all 49 state pairs.

### 6.2 The three decisions

| Step | Who | Rules |
|---|---|---|
| Reviewer sign-off | Reviewer | Not the author (BR-005); if a Reviewer is assigned, only that Reviewer (FR-039). Rejection needs a comment and returns the revision to Draft, clearing both sign-offs. |
| Administrator sign-off | Administrator | Not the author; may confirm/override audience-access values; rejection as above. |
| Chief Engineer approval | Chief Engineer | Not the author, and not whoever gave either earlier sign-off on that CR (BR-005). Rejection needs a comment. |

(v4) Each decision asks for the actor's password (step-up, SEC-026); a delegate with an active delegation may take a decision as themselves, with the same checks and the audit entry naming both people (FR-125, BR-017). A Chief Engineer may decide several requests of a change set in one sitting — each by its own check, comment and audit entry (FR-124).

The first two may happen in either order; the revision moves to PendingApproval **automatically, in the same transaction as the second sign-off** (FR-035). Segregation of duties is enforced in the service layer, by CHECK constraints on the table, and tested at all three points through the API and the UI.

### 6.3 Change request types

- **NEW** — a brand-new code. **REVISION** — copy-on-write of an existing code (editing in place is impossible after Draft, FR-025); only one open revision per code at a time (BR-003). **DEPRECATION** — opened against a Released code with a mandatory reason; runs the full three-decision cycle and lands the revision in Deprecated. **IMPORT** — a Draft created by a library import.
- An author can **withdraw** a CR in Draft, Review or PendingApproval (FR-026). Reviewers, Administrators and Chief Engineers can add plain **comments** that change nothing (FR-038). Administrators can **assign** the Reviewer (FR-039).

## 6.4 Releases

An Administrator creates a Release (name, version label, scope filter by group/subgroup), reviews the **candidates** (Approved, non-sandbox revisions matching the scope), chooses the included set, and **publishes**. Publishing moves every included revision to Released, stamps the effective date and freezes the Release — atomically (FR-040–FR-044). A Release can be deleted only before publishing (BR-008). (v4) Before publishing, target software versions may be set, which limit the candidates to revisions whose version range includes a target (BR-021); publishing needs the Administrator's password and warns about future planned dates; the published Release has release notes, a manifest and bundle exports, an offline lookup page, and fires the `release.published` webhooks after the commit. Sandbox revisions are excluded by the service and by a database trigger (FR-048).

## 6.5 Deprecation and archival

Deprecating a Released code is a CR with the full cycle (FR-050). An Administrator can archive a Deprecated code once the retention period (default 180 days, counted from the DEPRECATE audit entry) has passed (FR-051, BR-006), or reinstate it with a reason. Archived codes are read-only.

## 6.6 Sandbox codes

Administrator-only test codes with a `StCd-T#####` identifier, excluded from default search, exports and releases. They can be permanently deleted — the only deletable record type (database trigger) — and the deletion writes an audit entry containing a full snapshot of what was removed (FR-055, FR-056).

---

# 7. Functional description by area

| Area | Behaviour | Requirements |
|---|---|---|
| Authentication | Username or e-mail plus password; session cookie HttpOnly, Secure, SameSite=Strict; 30-minute idle and 12-hour absolute expiry; five failed logins lock the account 15 minutes; per-IP and per-username throttling; logout invalidates immediately. | FR-001–FR-004, SEC-002–SEC-004 |
| Users and roles | Administrators create/edit/deactivate users, assign exactly one role and domain tags, force password resets; the last active Administrator cannot be removed; passwords need 12+ characters, must not be on the block-list (seed_data/common_passwords.txt, replaceable with an internal corpus) and must differ from the user's last 5 passwords; default role is Viewer. | FR-010–FR-014, SEC-012, 11 §4 |
| Search and browse | Full-text over identifier, title, description; filters for group, subgroup, platform, state, owner, sandbox (excluded by default); sorting; pagination (default 50, max 200). Viewers see only Approved/Released/Deprecated/Archived data and keep seeing the last Released revision while a newer Draft is open. | FR-060–FR-064, BR-009 |
| Revision history and diff | All visible revisions; field-level comparison of any two; the CR page shows the differences from the last decided revision, or marks a new code. | FR-032, FR-064 |
| Exports | Per Release; all current Released codes (optionally filtered); an unapproved working set for the StCd Owner and the Administrator only (FR-175), labelled "Not for distribution – unapproved data" on every row, in the file name and on the PDF; all as flat tables in CSV, JSON, XLSX, PDF; cells that could be read as formulas are neutralised. Full-database backup is Administrator-only. | FR-045–FR-047, SEC-015, SEC-023 |
| Library import | CSV/XLSX upload (extension allow-list, 20 MB cap); each row validated like manual entry; valid rows become Drafts, invalid rows create nothing and appear in a downloadable error report; legacy numbers are kept in a separate field. | FR-048a–d, SEC-024 |
| Lookup administration | Administrators add/relabel/describe/deactivate vocabulary values; create Subgroups and whole Functional System Groups in free ranges; overlaps are refused (service and database trigger). | FR-048e–h |
| Audit log | Search by entity, actor, action, date. Administrators see everything; Reviewers and Chief Engineers a scoped subset. Entries cannot be changed or removed (database triggers). | FR-070–FR-073 |
| Dashboard | Role-specific counters and shortcuts (open CRs, requested domain sign-offs, awaiting sign-off/approval); since v4 also unread notices, stalled requests and backup state for Administrators. | S2 |
| (v4) Concurrency and soft checks | Stale Draft saves refused (409) with the user's entries kept; warnings for unknown/retired references and similar titles; Where-used; platform variants; planned dates. | FR-090 … FR-094, FR-109 |

| Area | Behaviour | Requirements |
|---|---|---|
| (v4) Workflow aids | SLA chips and stalled list; in-app notices and optional mail; delegation; change sets; field comments; review checklist; evidence; reviewer balancing; KPIs. | FR-120 … FR-131 |
| (v4) Publication | Export profiles; audience, language and version scoping; wrapped PDF; manifests, bundles and verification; release notes; offline bundle; translations; software-version matrix. | FR-100 … FR-111 |
| (v4.9 – v4.10) Menu, program fields, deletion | A menu grouped by the work of the user with counts (FR-169); the fields of the generated programs stored, edited, imported and exported (FR-168); users with history and withdrawn codes erased in place with the audit log untouched (BR-025, BR-026). | FR-168, FR-169 |
| (v4.13) Bulk workflow | The workbench of a change set: readiness of the Drafts, bulk edit, bulk submit, bulk domain sign-off and the bulk decisions of the three decision roles - each code through its own checks, a decision on more than a handful of codes only after a sample inspection by the person who decides - and the dossier (XLSX) for an auditor. | FR-180 |
| (v4.12) Connections | What suppresses a code, what it requires and where it escalates, read from the set condition and the repeat code of the imported programs; the code page shows them, the page Connections shows the causes as a tree, the escalation targets and what looks wrong. | FR-179 |
| (v4.10) Baseline and package | A Release export is the complete baseline of every code valid as of it, narrowed by platform and controller; one package holds every language for every access level with release notes and a manifest; everybody downloads released data, only the StCd Owner and the Administrator what is not released. | FR-173 … FR-175 |
| (v4) Import toolkit | Template, dry run, update mode, reconciliation, XLSX error report, background job with progress. | FR-048i … FR-048n |
| (v4.17) Mapping with three approvals | The legacy -> new mapping lives in the database (4 tables) and changes only by a request that the StCd Owner, the Chief Engineer and an Administrator all approve; requests for one row, ticked rows or a corrected workbook; Mapping and Mapping changes pages with Show all; the import takes title, type, up/down counter, access levels and remedy from it (FR-191 … FR-198, BR-027) | |
| (v4.18) Filters with several values | Panels of tick boxes on the Status Codes list, the mapping, its requests and the legacy mapping; any chosen value matches; repeated or comma-joined parameters in the API (FR-199) | |
| (v4.18.1) Input hardening, corpus report, API fuzz | Control characters refused, oversized identifiers are 404, flask corpus-report on a folder of real programs, a property-based fuzz of every API operation (TC-081 … TC-083) | |
| (v4.2) Status code import from programs | The generated StCd_.st programs (several files, a folder or a ZIP) are read as text, previewed per program with multi-select, and imported as ordinary Drafts that reserve the number the program carries and join one change set; Hub numbers are translated through the numbering table; every code keeps its source file, SHA-256 and parsed attributes; the legacy -> new mapping is listed and exported (one direction only). Uploads are size-limited, private to the uploader and expire after 24 hours. | FR-048o … FR-048w, BR-023, SEC-031 |
| (v4) Insight and integration | Catalogue health and capacity; saved searches and shareable views; fleet feedback; API tokens, change feed, webhooks; Hub-to-Main consolidation; ranked, typo-tolerant search. | FR-140 … FR-148 |
| (v4) Operations | Verified backups; audit hash chain, verification and archive; readiness and metrics; settings; German UI and help. | FR-150 … FR-155 |
| (v4.7 – v4.9) Languages | Nineteen interface languages, complete in all of them (every template text, flash message and service-layer sentence, 1,093 strings, FR-167); a language per user; the review of the translations by native speakers in the application; the PDF in every script; the technical nomenclature as a vocabulary of its own with a two-person approval and a consistency check against the interface; the Windows sign-in with a test gateway for a real Windows identity; the beta mark of unreviewed languages and the export text in the language of the export. | FR-155, FR-157, FR-162 … FR-171 |

## 7.1 Audit events

One hundred and one action codes can be written (`12-audit-compliance.md` §2; a test keeps the catalogue complete) — among them `CREATE`, `EDIT`, `SUBMIT_FOR_REVIEW`, `REVIEWER_SIGNOFF`, `ADMIN_SIGNOFF`, `CHIEF_ENGINEER_APPROVE/REJECT`, `DOMAIN_SIGNOFF(_REQUEST)`, `REVIEWER_ASSIGN`, `IDENTIFIER_OVERRIDE`, `RELEASE_CREATE/ITEMS_SET/PUBLISH/DELETE`, `DEPRECATE`, `REINSTATE`, `ARCHIVE`, `SANDBOX_CREATE/DELETE`, `CATALOGUE_EXPORT`, `FULL_DATABASE_EXPORT`, `IMPORT_STARTED/COMPLETED/FAILED`, `LOOKUP_CHANGE`, `SUBGROUP_CREATE`, the user and authentication events. Each entry records actor, UTC time, entity, before/after values, client address and request id, and is written in the same transaction as the change. Decision and comment entries include the comment id and full text; a withdrawal keeps a snapshot of the deleted discussion, so review

comments are never lost.

## 8. User interface

Fifty-five screens (S1–S55, `10-ui-ux-specification.md`; the nineteen of v3 are listed first, the v4 screens — notices, delegation, change sets, stalled requests, translations, release notes and shaped export, software versions, catalogue health, success metrics, fleet feedback, Hub consolidation, export profiles, review checklist, settings, integrations, operations and help, and in v4.2 the status code import from `.st` files and the legacy mapping — are added in the sidebar groups Workflow, Releases, Insight and Administration): Login; Dashboard; Status Code list; Status Code detail (Current / History / Deprecation tabs); New Status Code; New Sandbox Code; Edit Draft; My Change Requests; Review Queue; Approval Queue; Change Request detail/decision (diff, sign-off strip, cross-domain strip, comments, role-specific actions); Release list/new/builder/detail; User administration; Lookup administration (including Functional System Group and Subgroup creation); Audit log; Export Center; Account settings; Library Import.

Design rules implemented: sidebar navigation that adapts to the role; every validation failure re-displays the form with **all entered values intact** (NFR-007a); each lookup-backed dropdown shows the selected option's description as inline help, or an explicit "no description yet" note (NFR-007b); destructive actions use a confirmation dialog or a typed confirmation; no inline scripts, so the Content-Security-Policy can forbid them.

## 9. Interfaces

### 9.1 REST API

Versioned under `/api/v1`, JSON, session-cookie authentication plus `X-CSRFToken` on state-changing calls (`GET /auth/csrf-token`). The contract is `docs/artifacts/openapi.yaml` (v4.0.0, 171 operations; since v4 read-only machine consumers may also use `Authorization: Bearer cscm_?` tokens on the endpoints that declare a scope) and is checked against the running code by an automated test in both directions. Groups: auth and users; status codes and revisions (including diff); change requests (submit, the three decisions, withdraw, comments, reviewer assignment, domain sign-offs and requests); imports; releases; exports; lookups; audit log; health. Errors use `{"error": , "message": }` with 401 (not signed in), 403 (role or segregation of duties), 404, 409 (state conflict), 422 (validation, with a `field_errors` list), 429 (throttled).

### 9.2 Files

Imports: CSV or XLSX with a header row; columns include `functional_system_group`, `functional_subgroup`, `turbine_platforms` (semicolon-separated), `title`, `description`, `status_category`, `available_group`, `set_delay`, `reset_delay`, the optional behaviour/program/audience columns, and `legacy_reference_number`. Exports: one row per status code, every field a column. Uploaded files are stored under `instance/imports//` (outside any served path) and never served back to a browser. (v4.2) Status code programs: `.st`, `.scl`, `.exp`, `.txt` or one `.zip` (2 MB per file, 2,000 files and 50 MB unpacked per upload) through `POST /imports/st/preview` and `POST /imports/st`; the preview is kept under `instance/imports/staging/` and the confirmed files under `instance/imports//`.

### 9.3 Security headers

Every response carries a self-only Content-Security-Policy (no inline script, no framing), `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: same-origin`, `Cache-Control: no-store` (except static files), and HSTS on HTTPS requests (SEC-025).

## 10. Security summary

| Control | Implementation |
|---|---|
| Authentication | Argon2id hashes; lockout; throttling; per-request session re-validation |
| Authorization | Six roles; checked at the route and again in the service; domain-tag checks for cross-domain sign-off |
| Segregation of duties | Service checks + table CHECK constraints + tests at all three decision points |

| Control | Implementation |
|---|---|
| Data integrity | Foreign keys on; unique/partial indexes (one current and one open revision per code); triggers for locked revisions, sandbox-only deletion, release immutability, range overlap, append-only audit |
| Injection / XSS / CSRF | ORM-bound parameters only (bandit clean); Jinja auto-escaping; CSRF tokens; formula neutralisation in exports |
| Transport / headers | TLS at the reverse proxy; CSP and companion headers |
| Supply chain | Pinned requirements; pip-audit on every report run; static check that no cloud SDK or external asset is referenced |
| Confidentiality of exports | Role-scoped; working sets are watermarked; full-database export Administrator-only, password-confirmed and audited; audience exports disclose only what the Administrator confirmed as visible (v4) |
| (v4) Deliberate approvals | Step-up password; delegation limited to decisions, under segregation of duties |
| (v4) Tamper evidence | Hash-chained audit log with anchor and weekly verification; signed export manifests; verified backups |
| (v4) Machine access | Hash-only, scoped, expiring, read-only API tokens; webhooks to internal addresses only, signed, no redirects |
| (v4) Uploads | Allow-listed, content-checked, size-limited, stored outside the web root, download-only (evidence, imports) |

## 11. Configuration and operation

| Setting | Source | Default |
|---|---|---|
| FLASK_ENV | environment | development (production for live use) |
| SECRET_KEY | environment | required in production: at least 32 characters, not the development default and not the .env.example placeholder. A production instance refuses to start otherwise (session cookies are signed with it) |
| DATABASE_URL | environment | sqlite:///instance/cscm.db |
| Session idle timeout / absolute lifetime | app/config.py | 30 minutes / 12 hours |
| Lockout | app/config.py | 5 failures, 15 minutes |
| Upload size | app/config.py | 20 MB |
| Archive retention | application constant | 180 days |
| (v4) STEP_UP_REQUIRED | app/config.py | true |
| (v4) MANIFEST_SIGNING_KEY, AUDIT_HMAC_KEY | environment | unset (generated by the installers; recommended in production) |
| (v4) BACKUP_DIR, BACKUP_MAX_AGE_HOURS | environment | unset / 36 |
| (v4) CSCM_INSTANCE_PATH, LOG_FILE | environment | ./instance / unset |
| (v4) CSCM_HOST, CSCM_PORT, CSCM_THREADS, CSCM_TRUSTED_PROXY | environment (scripts/serve.py) | 127.0.0.1, 8000, 8, unset |
| (v4) METRICS_ALLOWED_CIDRS, METRICS_TOKEN | environment | loopback and RFC 1918 / unset |
| (v4) SMTP_HOST, SMTP_PORT, SMTP_SENDER, SMTP_STARTTLS, SMTP_USERNAME, SMTP_PASSWORD | environment | mail off |
| (v4) IMPORT_ASYNC_ROW_THRESHOLD | environment | 300 rows |
| (v4.13) the sample of a bulk decision (bulk.sample_percent, bulk.sample_minimum, bulk.sample_above) | Administration -> Settings (database) | 10 % of the batch, at least 8 codes, none for 5 or fewer |
| (v4) SLA thresholds, reviewer.auto_assign, capacity alert | Administration -> Settings (database) | review 3/5, approval 2/3 days; off; 15 % / 20 numbers |

(v4) Preferred bring-up and upgrade: the installer (`deploy/linux/install.sh` or `deploy/windows/install.ps1`, 14-deployment-architecture.md §4a), which does everything below, generates the keys, takes a verified backup before migrating and registers the web server, the nightly backup, the reminders and the weekly audit check. Manual bring-up on a new server:

```
python -m venv .venv && .venv\Scripts\activate
pip install -r requirements.txt
flask db upgrade            # creates the schema and seed vocabularies
flask create-admin          # the one place a first Administrator can be created
python scripts/serve.py                          # Waitress; behind the TLS reverse proxy
flask backup-db                                  # first verified backup (also scheduled)
```

Upgrading an existing installation: take a verified backup (`flask backup-db`), deploy the new code, run `flask db upgrade` (migrations are idempotent and reversible), run the smoke checks in the test report. Backup, TLS, file

permissions and egress blocking are deployment responsibilities described in `14-deployment-architecture.md`.

## 12. Quality attributes (measured)

| Attribute | Target | Measured (see 24-test-report.md §4) |
|---|---|---|
| Search latency, 20,000 revisions | p95 <= 500 ms | ~ 110 ms (ranked FTS search) |
| Single-record read | p95 <= 200 ms | ~ 4 ms |
| Export of 5,000 records | CSV/JSON <= 5 s; XLSX/PDF <= 15 s | ~ 0.5–0.7 s; ~ 1.7 s / 3.1 s |
| 50 concurrent users | keep the search target | ~ 72 ms p95 |
| Identifier allocation under contention | unique, gap-free | verified with 8 parallel writers |
| Maintainability | >= 80% coverage of service code; clean static analysis | 92% line coverage overall; black, ruff, mypy, bandit clean |

## 13. Known limitations and open items

1. Descriptions for lookup values (23 Available Group codes, eight program-reference fields, audience-access values) must be supplied by Controls Engineering; until then the inline help says so. The meaning of the value `Covert` is unconfirmed; it is treated as not visible (D-02).
2. The PDF prints every script of the offered languages (v4.7, FR-165) with bundled Noto fonts, but only in the regular weight (headings are not bold) and Urdu in Nastaliq needs a taller line than the table uses, so its tall letters can touch the cell border; a character that no bundled font draws is replaced by `?`.
3. The interface is translated completely into all nineteen languages (v4.9, FR-167), but the 18 translations besides English are proposals written by the maintainer's tooling that no native speaker has checked yet (an AI pre-check estimates that 78 % to 95 % of the strings would be accepted unchanged, FR-177, `26-translations.md` §8c; it is not a review); the messages of the API and the user manual stay English; the words around an export follow the language of the export (FR-171).
4. Business days have no holiday calendar.
5. Manifests are signed with a shared secret (HMAC); there is no asymmetric signature, so a verifier needs the same key.
6. Single-node SQLite bounds write throughput; the repository layer and the ratchet keep a PostgreSQL migration possible, but the application has never been run on PostgreSQL (Phase 3).
7. Background imports run in a thread of the web process; a restart during a large import leaves the job in its last recorded state and the file must be re-uploaded.
8. Business UAT sign-off and the production deployment checks (real installation, TLS, file permissions, blocked egress, restore drill, key custody, screen-reader pass) are outside what automated tests can prove (20-traceability-matrix.md §6).
9. Packages are built by a thread of the web process (as the imports, item 7) and their files stay under `instance/packages` until someone removes them; there is no Word output yet (I-43, I-66), and anybody signed in may start a build (see I-68).